

INSTITUTO INFNET
ESCOLA SUPERIOR DE TECNOLOGIA
GRADUAÇÃO EM ENGENHARIA DE
SOFTWARE



Turma - GRLENGR2C1-N2-L1
Curso - Desenvolvimento Seguro de
Aplicações Web
Professor - Fabiano Domingues

AT

Alunos: Ademir de Lucca Junior.

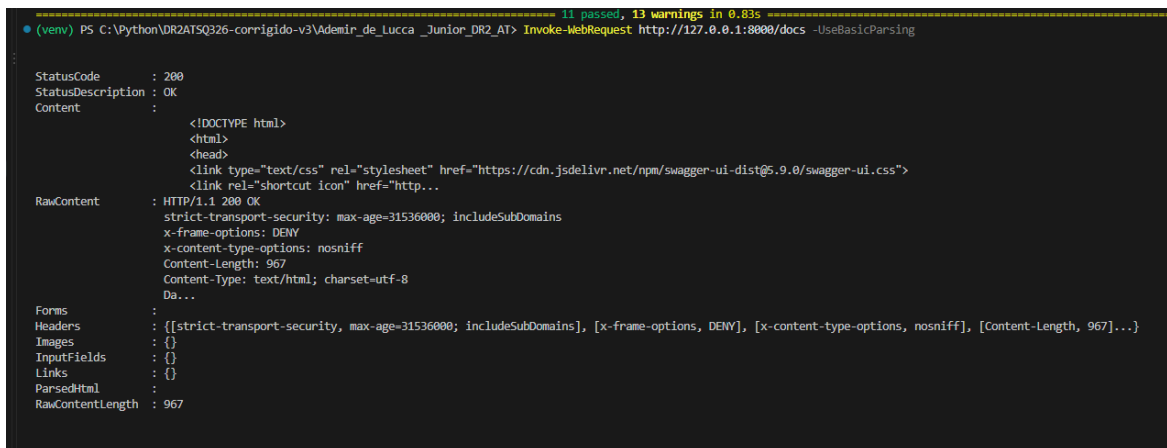
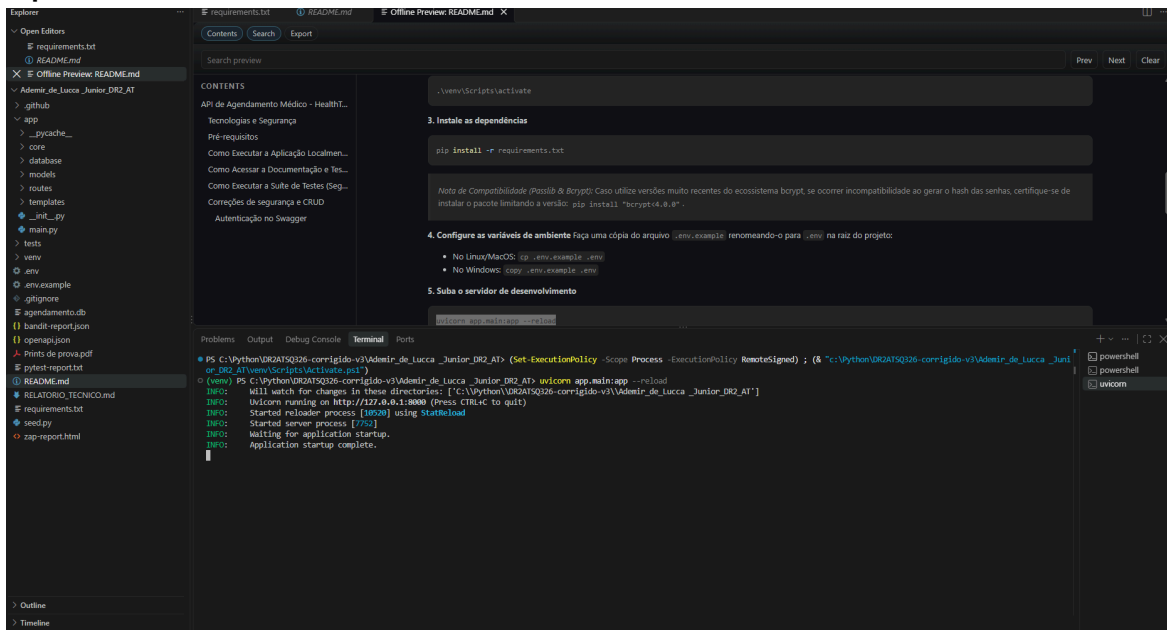
3 de out. de 2026

Exercícios

Github:

<https://github.com/yADMh/DR2ATSQ326/tree/main>

Api iniciada



Print do login

/auth/login

Parameters

No parameters

Request bodyapplication/x-www-form-urlencoded

grant_typestringpassword

☐ Send empty value

client_idstringclient_id

☒ Send empty value

client_secretstringclient_secret

☒ Send empty value

usernamestringpaciente1

☐ Send empty value

passwordstring123

☐ Send empty value

scopestringscope

☒ Send empty value

Execute

Clear

Responses

Curlcurl -X POST \n'http://localhost:8080/auth/login' \n-H 'accept: application/json' \n-M 'Content-Type: application/x-www-form-urlencoded' \n-d 'grant_type=password&client_id=&client_secret=paciente1&password=123&scope='

Request URLhttp://localhost:8080/auth/login

Server responseCodeDetails

Response body{"access_token":"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIjOiJmYWwpc2NlZS1lcDpCZWVudHkiLCJpCiwiYWR1cyI6ImFkbWwgPC9kbnMScGU1OjE1L3VyIlwic2NvcGVzfjpbInklYQ6Y29uc3VsZXdfziIiwid3ppdGUiOiJyZXRvaGRicSIPTA3ODAAAH0.mKEyVFStmcnIdt9Z579plK636vjdqfIBC6Urtvnrl","token_type":"bearer"}

Available authorizations

BearerAuth (http, Bearer)

Cole aqui o JWT obtido em /auth/login. Não inclui a palavra Bearer.

Value:

Authorize

Close

Available authorizations

x

BearerAuth (http, Bearer)

Authorized

Cole aqui o JWT obtido em /auth/login. Não inclua a palavra Bearer.

Value: *****

Logout

Close

pytest

```
Problems Output Debug Console Terminal Ports
• PS C:\Python\DR2ATSQ326-corrigido-v3\Ademir_de_Lucca_Junior_DR2_AT> (Set-ExecutionPolicy -Scope Process -ExecutionPolicy RemoteSigned) ; (& "C:\Python\DR2ATSQ326-corrigido-v3\Ademir_de_Lucca_Junior_DR2_AT\venv\Scripts\Activate.ps1")
• (venv) PS C:\Python\DR2ATSQ326-corrigido-v3\Ademir_de_Lucca_Junior_DR2_AT> python -m pytest -v

===== test session starts =====
platform win32 -- Python 3.11.9, pytest-8.1.1, pluggy-1.6.0 -- C:\Python\DR2ATSQ326-corrigido-v3\Ademir_de_Lucca_Junior_DR2_AT\venv\Scripts\python.exe
cachedir: .pytest_cache
rootdir: C:\Python\DR2ATSQ326-corrigido-v3\Ademir_de_Lucca_Junior_DR2_AT
plugins: anyio-4.15.1
collected 11 items

tests/test_consultas.py::test_stored_xss_mitigation PASSED [ 9%]
tests/test_consultas.py::test_200_com_ownership PASSED [ 18%]
tests/test_consultas.py::test_403_sem_ownership_bola PASSED [ 27%]
tests/test_consultas.py::test_m2m_nao_bypassa_ownership PASSED [ 36%]
tests/test_consultas.py::test_crud_list_update_delete_routes_exist PASSED [ 45%]
tests/test_consultas.py::test_422_payload_invalid_extra_forbid PASSED [ 54%]
tests/test_seguranca.py::test_401_sem_token PASSED [ 63%]
tests/test_seguranca.py::test_usuario_nao_admin_recoba_403_na_rota_admin PASSED [ 72%]
tests/test_seguranca.py::test_agenda_exige_autenticacao PASSED [ 81%]
tests/test_seguranca.py::test_scopes_nao_podem_ser_escolhidos_pelo_cliente PASSED [ 90%]
tests/test_seguranca.py::test_rate_limiting PASSED [100%]

===== warnings summary =====
venv\Lib\site-packages\starlette\types.py:41
  venv\Lib\site-packages\starlette\types.py:41: DeprecationWarning: The `starlette.types.Path` type is deprecated. Please use `typing_extensions.Literal` instead.
```

Sem JWT

Consultas

GET /consultas/ Listar Consultas

Parameters

No parameters

Execute Clear

Responses

Curl

curl -X 'GET' \n'http://localhost:8080/consultas/' \n-H 'accept: application/json'

Request URL

http://localhost:8080/consultas/

Server response

Code	Details
401	Error: Unauthorized

Response body

{\n "detail": "Not authenticated"\n}

Response headers

content-length: 30\ncontent-type: application/json\ndate: Sun, 04 Oct 2026 01:47:35 GMT\nserver: unicorn\nstrict-transport-security: max-age=31536000; includeSubDomains\nwww-authenticate: Bearer\nx-content-type-options: nosniff\nx-frame-options: DENY

Responses

Code	Description	Links
200	Successful Response	No links

Media type

application/json

Content-Accept header

6

Rate Limiting

Request body

application/x-www-form-urlencoded

grant_type

string

client_credentials

☐ Send empty value

client_id

string

agenda_lab

☐ Send empty value

client_secret

string

Lab_2026_DR2_AT_9fK7xP2m

☐ Send empty value

username

string

username

☒ Send empty value

password

string

password

☒ Send empty value

scope

string

scope

☒ Send empty value

Execute

Clear

Responses

Curl

```
curl -X 'POST' \
  'http://localhost:8000/auth/login' \
  -H 'accept: application/json' \
  -H 'Content-Type: application/x-www-form-urlencoded' \
  -d 'grant_type=client_credentials&client_id=agenda_lab&client_secret=Lab_2026_DR2_AT_9fK7xP2m&username=username&password=password&scope='
```

Request URL

http://localhost:8000/auth/login

Server response

Code

Details

429

Error: Too Many Requests

Undocumented

Response body

```
{
  "error": "Rate limit exceeded: 5 per 1 minute"
}
```

Response headers

```
access-control-allow-credentials: true
content-length: 47
content-type: application/json
date: Sun, 04 Oct 2026 01:49:26 GMT
server: nginx
```

post consulta funcionando

Consultas

POST /consultas/ Criar Consulta

Parameters Cancel Reset

No parameters

Request body required application/json

Edit Value | Schema

```
{
  "paciente_id": 1,
  "profissional_id": 1,
  "data_horario": "2026-09-21T23:34:16.024Z",
  "especialidade": "string"
}
```

Execute Clear

Responses

Curl

```
curl -X 'POST' \
  'http://127.0.0.1:8000/consultas/' \
  -H 'accept: */*' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ2aWQiOiJ1OTI1ZmRlY296ZmZlY29uc3VsZGFzOnJ1YmQ1IiwiaWF0Ijpb25mdW90N6d3pdG1KXSwi9hZ3Zlcm1maW1ja290cnVlIiwiaWF0IjE3OTAwMzUzNjR9.GG' \
  -H 'Content-Type: application/json' \
  -d '{
    "paciente_id": 1,
    "profissional_id": 1,
    "data_horario": "2026-09-21T23:34:16.024Z",
    "especialidade": "string"
  }'
```

Request URL

http://127.0.0.1:8000/consultas/

Server response

Code Details

200

Response body

```
{
  "id": 50,
  "paciente_id": 1,
  "profissional_id": 1,
  "data_horario": "2026-09-21T23:34:16.024000",
  "especialidade": "string",
  "status": "agendada"
}
```

Download

Swagger

Auth		
POST	/auth/login Login	
Consultas		
GET	/consultas/ Listar Consultas	
POST	/consultas/ Criar Consulta	
GET	/consultas/{consulta_id} Ler Consulta	
PUT	/consultas/{consulta_id} Atualizar Consulta	
DELETE	/consultas/{consulta_id} Excluir Consulta	
Admin		
GET	/admin/usuarios Listar Usuarios	
M2M		
GET	/m2m/agenda/disponibilidade Consultar Disponibilidade	
default		
GET	/agenda Read Agenda	
Schemas		

get consulta funcionando

GET

/consultas/{consulta_id} Obter Consulta

Parameters

NameDescription

consulta_id * requiredinteger(path)

1

ExecuteClear

Responses

Curl

```
curl -X "GET" \  
    "http://127.0.0.1:8000/consultas/1" \  
    -H "accept: */*" \  
    -H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpvcC9yZmkiOiJlczVpdGVzdGU1LCJ2ZWx0M01vY29uc3VsdcFzaWQilCljb25zdmdwZXNkdj3pdGlXSXBldWh3E3ZlcmAwMTJpbCnVLCTleHAloJE3OTAtMzMtuzkj" --proto https
```

Request URL

http://127.0.0.1:8000/consultas/1

Server response

CodeDetails

200Response body

```
{  
  "id": 1,  
  "paciente_id": 99,  
  "profissional_id": 1,  
  "data_hora_io": "2026-09-20T11:22:41.105456",  
  "especialidade": "cardiologia",  
  "status": "agendada"  
}
```

Download

Response headers

```
content-length: 139  
content-security-policy: default-src 'self'; script-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net; img-src 'self' data;  
content-type: application/json  
date: Mon, 21 Sep 2026 23:36:13 GMT  
server: uvicorn  
strict-transport-security: max-age=31536000; includeSubDomains  
x-content-type-options: nosniff  
x-frame-options: DENY
```

Responses

CodeDescriptionLinks

200Successful ResponseNo links

Media type

application/json▼

Controls Account header

MFA simulado/proteção do admin

grant_type
string

password

☐ Send empty value

client_id
string

client_id

☒ Send empty value

client_secret
string

client_secret

☒ Send empty value

username
string

admin

☐ Send empty value

password
string

123

☐ Send empty value

scope
string

scope

☒ Send empty value

Execute

Clear

Responses

Curl

```
curl -X 'POST' \
'http://localhost:8000/auth/login' \
-H 'accept: application/json' \
-H 'Content-Type: application/x-www-form-urlencoded' \
-d 'grant_type=password&client_id=&client_secret=&username=admin&password=123&scope='
```

Request URL

```
http://localhost:8000/auth/login
```

Server response

Code	Details
401 Undocumented	Error: Unauthorized Response body <pre>{ "detail": "MFA required" }</pre> Response headers

ERRO 422

No parameters

Request body required

application/json

```
{
  "medico_id": 1,
  "especialidade": "Ortopedia",
  "data_horario": "2026-10-11T14:30:00",
  "observacoes": "Dores no joelho direito.",
  "is_admin": true,
  "role": "admin"
}
```

Execute

Clear

Responses

Curl

```
curl -X 'POST' \
  'http://localhost:8000/consultas/' \
  -H 'accept: application/json' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJ1bWp7Z8IiwiaWF0IjoiInJvbmU101IjZmPjY2IiCj279wZXM101sicmVhZDpjb25zdXw9YXN1Cj3cm16ZTprjb25zdXw9YXN1XSwiZXhwIjoxNzAxMDY0YXZxfgQ.WmF...
```

Request URL

```
http://localhost:8000/consultas/
```

Server response

Code	Details
422	Error: Unprocessable Entity Response body <pre>{ "detail": [{ "type": "extra_forbidden", "loc": ["body", "is_admin"], "msg": "Extra inputs are not permitted", "input": true, "url": "https://errors.pydantic.dev/2.6/v/extra_forbidden" }, { "type": "extra_forbidden", "loc": ["body", "role"], "msg": "Extra inputs are not permitted", "input": "admin", "url": "https://errors.pydantic.dev/2.6/v/extra_forbidden" }] }</pre> Download

M2M Login

No parameters

Request body application/x-www-form-urlencoded ▾

grant_type
string

☐ Send empty value

client_id
string

☐ Send empty value

client_secret
string

☐ Send empty value

username
string

☒ Send empty value

password
string

☒ Send empty value

scope
string

☒ Send empty value

Execute
Clear

Responses

Curl

```
curl -X "POST" \
'http://localhost:8000/auth/login' \
-H 'accept: application/json' \
-H 'Content-Type: application/x-www-form-urlencoded' \
-d 'grant_type=client_credentials&client_id=agenda_lab&client_secret=Lab_2026_DR2_AT_09K7AP2m&username=&password=&scope='
```

Request URL

http://localhost:8000/auth/login

Server response

Code	Details
200	Response body <pre style="background-color: #2d2d2d; color: #eee; padding: 10px; font-family: monospace;">{ "access_token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjZvZGFmdGF1IiwiaWF0IjOjE5OTcwODAwMD19.X4FasP58l8Bwvs_P7ZVP6cTztPdImtIgISmhhuo", "token_type": "bearer" }</pre> Download Response headers <pre style="background-color: #2d2d2d; color: #eee; padding: 10px; font-family: monospace;">access-control-allow-credentials: true content-length: 250 content-type: application/json date: Sun, 04 Oct 2026 01:44:48 GMT server: uvicorn strict-transport-security: max-age=31536000; includeSubDomains x-content-type-options: nosniff x-frame-options: DENY</pre>

Responses

Code	Description	Links
200	Successful Response	No links

Media type

application/json ▾

Endpoint M2M

M2M

GET /m2m/agenda/disponibilidad
[Consultar Disponibilidad](#)
🔒 🔑

Parameters
Cancel

No parameters

Execute
 Clear

Responses

```
Curl
curl -X 'GET' \
  https://localhost:8000/m2m/agenda/disponibilidad \
  -H 'accept: application/json' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6ImlkiLC3bZ2VudDFFbGF1Iiwic3RhbnQ6ImFkZXNjaWwibGFiIlwic2NvcC0vZjpbImdybW9rIy29wZS3dC3lhdAIDJEKOTkwODAwOD19.X4fAsP8'
```

Request URL
http://localhost:8000/m2m/agenda/disponibilidad

Server response

Code	Details
200	Response body <pre>{ "ocupados": [] }</pre> Download Response headers <pre>content-length: 15 content-type: application/json date: Sun, 04 Oct 2025 01:46:05 GMT server: nginx strict-transport-security: max-age=31536000; includeSubDomains x-content-type-options: nosniff x-frame-options: DENY</pre>

Responses

Code	Description	Links
200	Successful Response Media type application/json ▼ Controls Accept header. Example Value Schema <pre>"string"</pre>	No links

M2M tentando acessar /consultas/

Consultas

GET /consultas/ Listar Consultas

Parameters

No parameters

Execute Clear

Responses

Curl

```
curl -X 'GET' \
  'http://localhost:8000/consultas/' \
  -H 'accept: application/json' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IWRXVCT9LjZkdWVudGFibGFIiSwicHbmMpcGFx3R5cGU1O1tHmELL7yb2V1IjoiYm9GF1iSwic2NvcGVzIjpbImR5bW9rY29uZS3dCj1leHA1OjE3OTFwODAwOD19Lk44FasoP5s'
```

Request URL

http://localhost:8000/consultas/

Server response

Code Details

403 Error: Forbidden

Response body

```
{
  "detail": "Permissons insuficientes para este escopo"
}
```

Response headers

```
content-length: 54
content-type: application/json
date: Sun, 04 Oct 2026 01:46:47 GMT
server: uvicorn
strict-transport-security: max-age=31536000; includeSubDomains
x-content-type-options: nosniff
x-frame-options: DENY
```

Responses

Code	Description	Links
200	Successful Response	No links

Media type: application/json

Control Accept header

Example Value | Schema

XSS Jinja2

Consultas

POST /consultas/ Criar Consulta

Parameters

No parameters

Request body *required* application/json

```
{
  "medico_id": 1,
  "especialidade": "Clinica Geral",
  "data_horario": "2026-10-12T09:00:00",
  "observacoes": "<script>alert('PALHA GRAVE XSS!')</script>"
}
```

Execute Clear

Responses

Curl

```
curl -X 'POST' \
  'http://localhost:8080/consultas/' \
  -H 'accept: application/json' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpzYW5kIiwiaWF0Ijoi2026-10-12T09:00:00Z', \
  -H 'Content-Type: application/json' \
  -d '{
    "medico_id": 1,
    "especialidade": "Clinica Geral",
    "data_horario": "2026-10-12T09:00:00",
    "observacoes": "<script>alert('PALHA GRAVE XSS!')</script>"
  }'
```

Request URL

http://localhost:8080/consultas/

Server response

Code Details

200

Response body

```
{
  "id": 1,
  "paciente_id": 1,
  "medico_id": 1,
  "especialidade": "Clinica Geral",
  "data_horario": "2026-10-12T09:00:00"
}
```

Response headers

```
access-control-allow-credentials: true
content-length: 107
content-type: application/json
date: Sat, 03 Oct 2026 20:32:36 GMT
server: uvicorn
strict-transport-security: max-age=31536000; includeSubDomains
```

get consultado com erro(BOLA e IDOR)


```

PS C:\Python\DR2ATSQ326-corrigido-v3\Ademir_de_Lucca_Junior_DR2_AT> python -m bandit -r app -f json -o bandit-report.json
[main] INFO profile include tests: None
[main] INFO profile exclude tests: None
[main] INFO cli include tests: None
[main] INFO cli exclude tests: None
[json] INFO JSON output written to file: bandit-report.json
(venv) PS C:\Python\DR2ATSQ326-corrigido-v3\Ademir_de_Lucca_Junior_DR2_AT> Get-Item .\bandit-report.json |
Select-Object Name, Length, LastWriteTime

Name                               Length LastWriteTime
----
bandit-report.json                 4491 03/10/2026 22:16:54

(venv) PS C:\Python\DR2ATSQ326-corrigido-v3\Ademir_de_Lucca_Junior_DR2_AT> python -m bandit -r app
[main] INFO profile include tests: None
[main] INFO profile exclude tests: None
[main] INFO cli include tests: None
[main] INFO cli exclude tests: None
[main] INFO running on Python 3.11.9
Run started:2026-10-04 01:17:06.227795

Test results:
  No issues identified.

Code scanned:
  Total lines of code: 485
  Total lines skipped (#nosec): 0

Run metrics:
  Total issues (by severity):
    Undefined: 0
    Low: 0
    Medium: 0
    High: 0
  Total issues (by confidence):
    Undefined: 0
    Low: 0
    Medium: 0
    High: 0
Files skipped (0):
(venv) PS C:\Python\DR2ATSQ326-corrigido-v3\Ademir_de_Lucca_Junior_DR2_AT>

```

ZAP

Generated on Sat, 3 Oct 2026 22:24:07

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	0
Low	0
Informational	0
False Positives	0

Insights

Level	Reason	Site	Description	Statistic
-------	--------	------	-------------	-----------

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
------	------------	---------------------

Alert Detail

Sequence Details

With the associated active scan results.

